



Au cœur de vos attentes. *En réponse à vos besoins*

Formation : *ASRS / TISR*

Module 4 : IDS / IPS | Firewall



Table des matières

- 1 : Firewall Linux
- 2 : Firewall Windows
- 3 : IDS / IPS





Firewall Linux



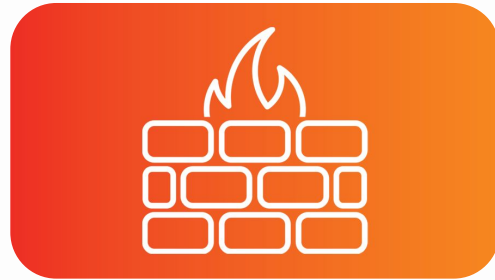
Est-ce utile d'avoir un Firewall ?

Filtrage de paquet

- accepter des paquets
- refuser des paquets

Exemple contre le bruteforce :

- Empêcher l'authentification frénétique d'une personne à une page de connexion, limiter les tentatives à 4.



Type de Firewall

Filtrage simple de paquets (Stateless)

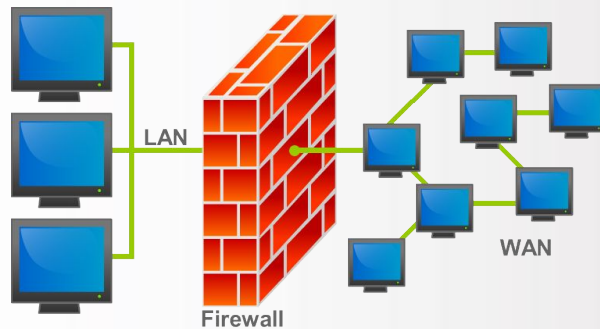
- IP source / destination
- Port source / destination
- Protocole niveau $\frac{3}{4}$

Filtrage de paquet avec état (Stateful)

- Agir sur l'état de la connexion (initialisation, établie...)

Filtrage applicatif (proxy applicatif)

- Réalisé au niveau de la couche 7 du modèle OSI (couche applicatif)



Iptables

- Installé par défaut sur la majorité des distributions Linux.
- Interface en ligne de commande permettant de configurer Netfilter.

```
$ sudo iptables -h
iptables v1.8.5

Usage: iptables -[ACD] chain rule-specification [options]
       iptables -I chain [rulenum] rule-specification [options]
       iptables -R chain rulenum rule-specification [options]
       iptables -D chain rulenum [options]
       iptables -[LS] [chain [rulenum]] [options]
       iptables -[FZ] [chain] [options]
       iptables -[NX] chain
       iptables -E old-chain-name new-chain-name
       iptables -P chain target [options]
       iptables -h (print this help information)
```

Iptables (Les chaînes)

Les chaînes :

- INPUT : Cette chaîne traitera les paquets entrants avant qu'ils ne soient passés aux couches supérieures (les applications).
- FORWARD : Ce sont les paquets uniquement transmis par la machine sans que les applications n'en aient connaissance.
- OUTPUT : Cette chaîne sera appelée pour des paquets envoyés par des programmes présents sur la machine.

Iptables (Les cibles)

Les cibles :

- ACCEPT : Les paquets envoyés vers cette cible seront tout simplement acceptés et pourront poursuivre leur cheminement au travers des couches réseaux.
- DROP : Cette cible permet de jeter des paquets qui seront donc ignorés.
- REJECT : Permet d'envoyer une réponse à l'émetteur pour lui signaler que son paquet a été refusé.
- LOG : Demandé d'enregistrer des informations dans le fichier `/var/log/messages` selon la configuration de `syslogd`.

Iptables (Stateless)

- `iptables -A INPUT -p tcp -s 192.168.1.0/24 -m tcp --dport 80 -j ACCEPT`
 - `-A INPUT` : tout trafic entrant
 - `-p tcp` : utilisant le protocole TCP
 - `-s 192.168.1.0/24` : provenant du sous réseau 192.168.1.0/24
 - `-m tcp` : correspond au TCP (-m ou match)
 - `--dport 80` : à destination du port 80
 - `-j ACCEPT` : l'accepter

```
$sudo iptables -L
Chain INPUT (policy ACCEPT)
target     prot opt source                destination          tcp dpt:http
```

Iptables (Stateless)

- `iptables -A OUTPUT -o eth0 -p tcp --sport 80 -j ACCEPT`
 - `-A OUTPUT` : tout trafic sortant
 - `-o eth0` : sur l'interface eth0
 - `-p tcp` : utilisant le protocole TCP
 - `--sport 80` : utilisant le port 80 comme port source
 - `-j ACCEPT` : l'accepter

```
Chain OUTPUT (policy ACCEPT)
num  target      prot opt source                destination           tcp spt:http
1    ACCEPT      tcp  --  anywhere              anywhere
```

Iptables (Stateful)

- `iptables -A INPUT -p tcp --dport 80 -m state --state NEW,ESTABLISHED -j DROP`
 - `-A INPUT` : tout trafic entrant
 - `-p tcp` : utilisant le protocole TCP
 - `--dport 80` : à destination du port 80
 - `-m state` : correspond à un état (`-m` ou `--match`)
 - `--state NEW,ESTABLISHED` : dont l'état est initialisation ou bien connexion déjà établie
 - `-j DROP` : le refuser

```
Chain INPUT (policy ACCEPT)
num  target      prot opt source      destination
1    DROP        tcp  --  anywhere    anywhere    tcp dpt:http state NEW,ESTABLISHED
```

Iptables (Commands)

<code>iptables -L</code>	lister les règles actives
<code>iptables -L --line-numbers</code>	afficher les règles avec les numéros de ligne
<code>iptables -F</code>	supprimer l'ensemble des règles de toutes les chaînes
<code>iptables -F "nom de la chaîne"</code>	supprimer l'ensemble des règles de la chaîne
<code>iptables -D "nom de la chaîne" "num de la règle"</code>	supprimer uniquement une règle de la chaîne
<code>iptables -h</code>	afficher l'aide iptables



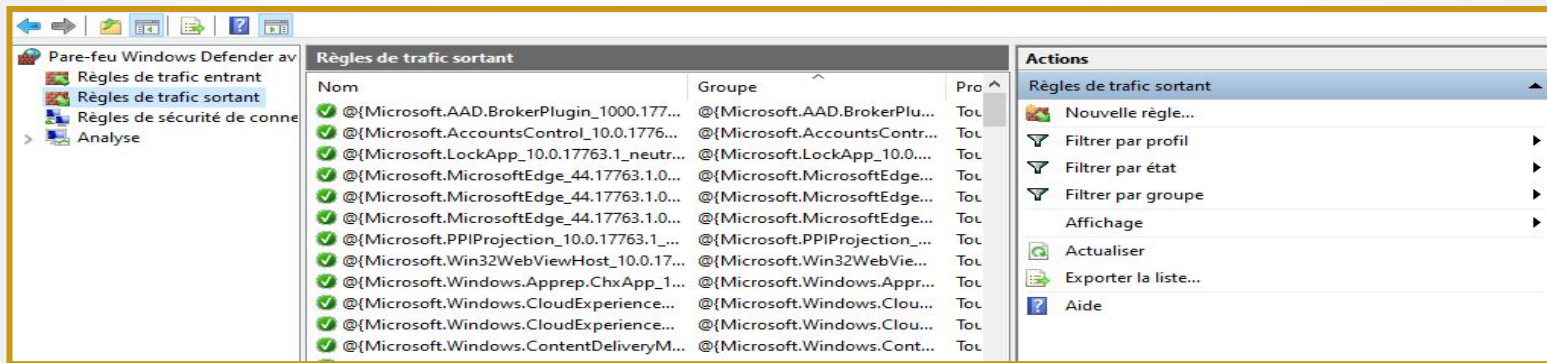
Firewall Windows



Firewall Windows

Accès au pare-feu windows :

- Panneau de configuration\Systeme et sécurité\Pare-feu Windows
- Une fois à ce niveau, dirigez-vous sur Paramètres avancés pour pouvoir éditer des règles de Pare-feu.



Firewall Windows

Comme avec les iptables nous pouvons gérer les règles du trafic entrant et sortant.

- Étape 1 : Mettre en personnalise le type de règle.

The screenshot shows the 'Étapes' (Steps) sidebar on the left with the following items: 'Type de règle' (selected), 'Programme', 'Protocole et ports', 'Étendue', 'Action', 'Profil', and 'Nom'. The main area is titled 'Quel type de règle voulez-vous créer ?' (Which type of rule do you want to create?). It contains four radio button options: 'Programme' (Rule that controls connections of a program), 'Port' (Rule that controls connections of a TCP or UDP port), 'Prédéfinie' (Predefined) with a dropdown menu showing '@FirewallAPI.dll,-80200', and 'Personnalisée' (Custom) which is selected. The description for 'Personnalisée' is 'Règle personnalisée.' (Custom rule).

Firewall Windows

- Étape 2 : Appliquez la règle à tous les programmes.

Étapes :

- Type de règle
- Programme**
- Protocole et ports
- Étendue
- Action
- Profil
- Nom

Cette règle s'applique-t-elle à tous les programmes ou à un programme spécifique ?

☒ **Tous les programmes**
La règle s'applique à toutes les connexions de l'ordinateur qui correspondent à d'autres propriétés de règles.

☐ **Au programme ayant pour chemin d'accès :**

Parcourir...

Exemples : c:\chemin\program.exe
%ProgramFiles%\Internet Explorer\iexplore.exe

Services

Vous pouvez également spécifier à quels services cette règle s'applique.

Personnaliser...

Firewall Windows

- Étape 3 : Précisez les protocoles que vous souhaitez bloquer.

The screenshot shows the 'Étape 3 : Précisez les protocoles que vous souhaitez bloquer' window in Windows Firewall. On the left, a sidebar titled 'Étapes :' lists the steps: 'Type de règle', 'Programme', 'Protocole et ports' (which is highlighted), 'Étendue', 'Action', 'Profil', and 'Nom'. The main area is titled 'À quels ports et protocoles cette règle s'applique-t-elle ?'. It contains the following fields:

- 'Type de protocole :' with a dropdown menu set to 'ICMPv4'.
- 'Numéro de protocole :' with a spinner box set to '1'.
- 'Port local :' with a dropdown menu set to 'Tous les ports' and an empty text box below it. An example 'Exemple : 80, 443, 5000-5010' is shown.
- 'Port distant :' with a dropdown menu set to 'Tous les ports' and an empty text box below it. An example 'Exemple : 80, 443, 5000-5010' is shown.
- 'Paramètres ICMP (Internet Control Message Protocol) :' with a 'Perso...' button.

- Étape 4 : Définissez les adresses IP locales et distantes pour cette règle.

The screenshot shows the 'Étape 4' (Step 4) configuration window for a Windows Firewall rule. On the left, a sidebar lists the steps: 'Type de règle', 'Programme', 'Protocole et ports', 'Étendue' (highlighted), 'Action', 'Profil', and 'Nom'. The main area is titled 'À quelles adresses IP locales cette règle s'applique-t-elle ?' (To which local IP addresses does this rule apply?). It has two radio buttons: 'Toute adresse IP' (selected) and 'Ces adresses IP :'. Below the radio buttons is a large empty text box for entering local IP addresses. To the right of this box are three buttons: 'Ajouter...', 'Modifier...', and 'Supprimer'. Below this section is a link 'Personnaliser les types d'interfaces auxquels cette règle s'applique :' followed by a 'Perso...' button. The second section is titled 'À quelles adresses IP distantes cette règle s'applique-t-elle ?' (To which remote IP addresses does this rule apply?). It also has two radio buttons: 'Toute adresse IP' (selected) and 'Ces adresses IP :'. Below the radio buttons is another large empty text box for entering remote IP addresses. To the right of this box are three buttons: 'Ajouter...', 'Modifier...', and 'Supprimer'.

- Étape 5 : Bloquer ou autoriser la connexion.

Étapes :

- Type de règle
- Programme
- Protocole et ports
- Étendue
- Action**
- Profil
- Nom

Quelle action entreprendre lorsqu'une connexion répond aux conditions spécifiées ?

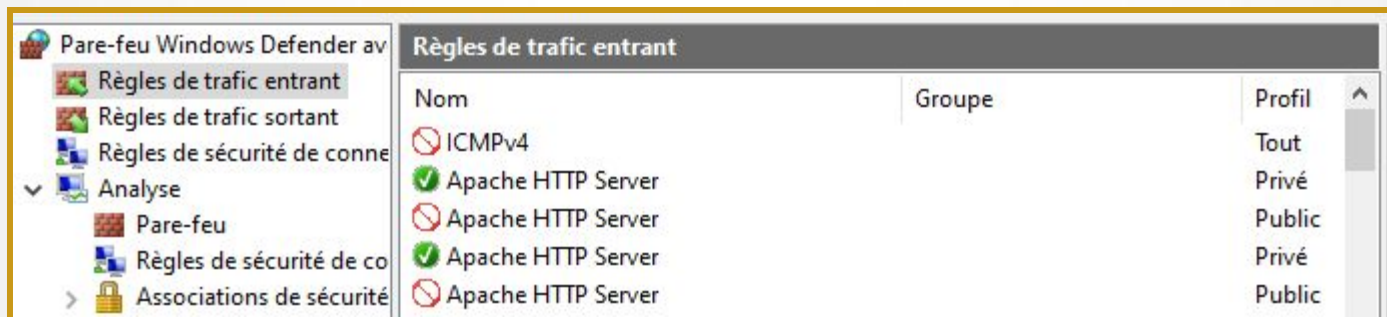
☐ **Autoriser la connexion**
Cela comprend les connexions qui sont protégées par le protocole IPsec, ainsi que celles qui ne le sont pas.

☐ **Autoriser la connexion si elle est sécurisée**
Cela comprend uniquement les connexions authentifiées à l'aide du protocole IPsec. Les connexions sont sécurisées à l'aide des paramètres spécifiés dans les propriétés et règles IPsec du nœud Règle de sécurité de connexion.

☒ **Bloquer la connexion**

Firewall Windows

- Le protocole ICMPv4 est donc bloqué sur le trafic entrant.





IDS / IPS



IDS (Intrusion Detection System)

Objectif

Repérer tout type de trafic pouvant être malveillant.



Surveiller les activités d'une cible :

- Réseau / Machine Hôte



Détecter les activités s'éloignant de la norme.

Exemple

- Tentative d'intrusion
- Attaques virales
- Débit trop important
- Trafic suspect

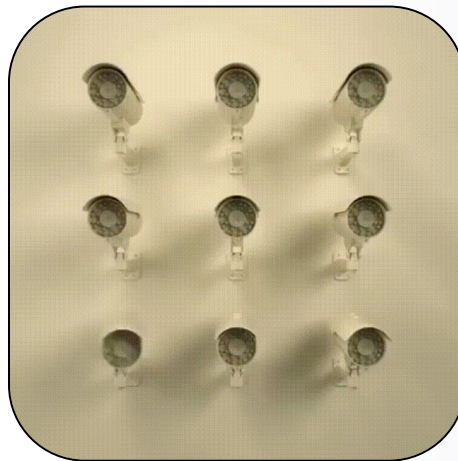
NIDS (IDS - Réseau)

Objectif

Surveiller l'état de la sécurité du réseau.

Il est isolé et ne voit qu'une copie du trafic (paquet du réseau).

S'il y a détection d'une menace, alors il peut ordonner le blocage d'un flux.

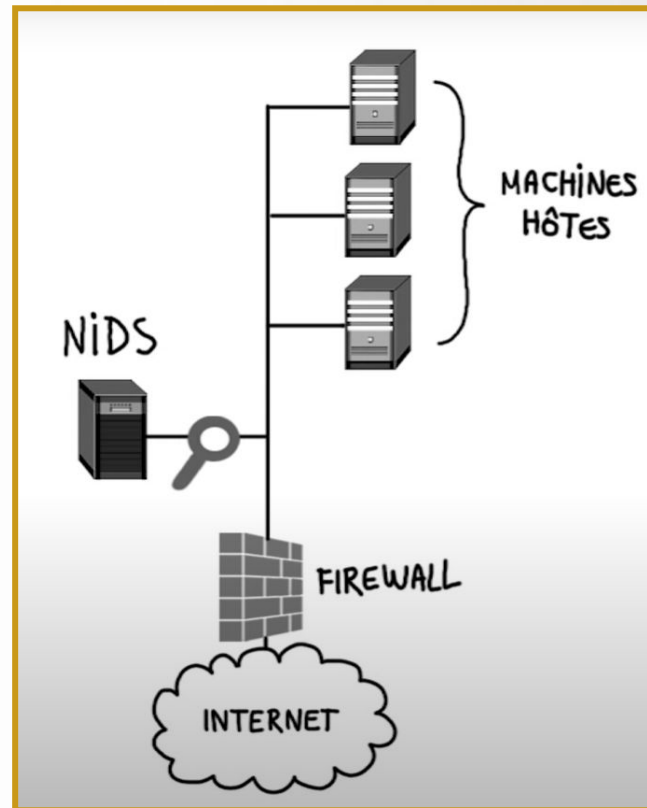


Architecture Technique NIDS

- Se situe sur un réseau isolé
- Ne voit qu'une copie du trafic du réseau à surveiller
- Ne communique pas avec le réseau surveillé



PASSIF



HIDS (IDS - Hôte)

Objectif

Surveiller l'état de la sécurité des hôtes sur plusieurs critères.

Analyse des activités de la machine hôte :

- Nombre et liste des processus
- Nombre d'utilisateurs
- Ressources consommées



HIDS (IDS - Hôte)

Objectif

Surveiller l'état de la sécurité des utilisateurs sur plusieurs critères.

Analyse des activités de l'utilisateur :

- Horaire et durée de connexions
- Commandes utilisées
- Programmes activés



HIDS (IDS - Réseau)

Objectif

Surveiller l'état de la sécurité des hôtes sur plusieurs critères.

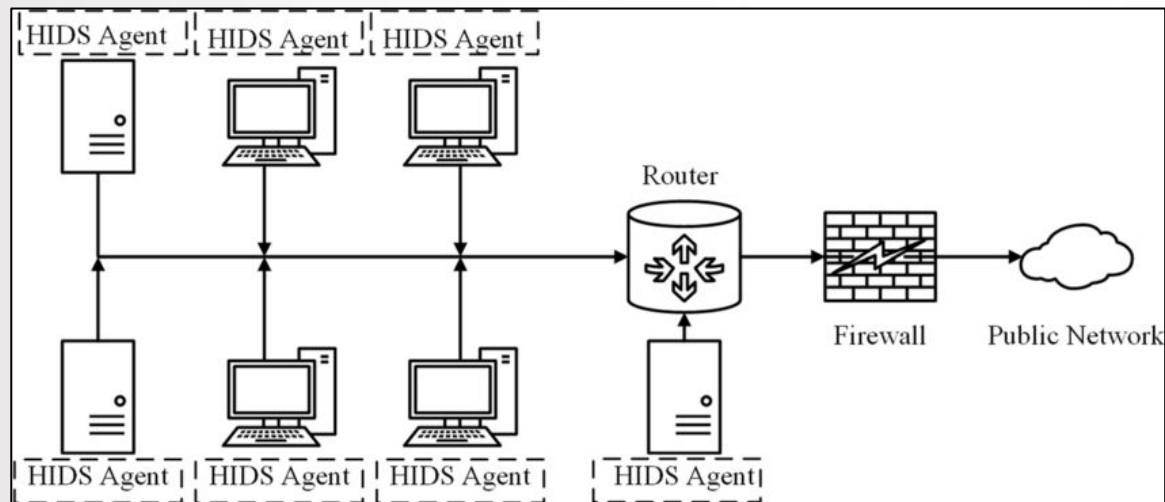
Analyse des activités suspectes :

- ver
- virus
- cheval de troie



Architecture Technique HIDS

- Récupère les informations remontées par les machines hôtes
- Analyse ces informations
- Surveille l'état de sécurité des machines hôtes



IPS (Intrusion Prevention System)

Objectif

Analyser les données et réagir s'il y a du trafic suspect.



Les données vont passer directement à travers l'IPS.



Stopper le trafic suspect qu'il reconnaît, en bloquant les ports.

Exemple

- Tentative d'intrusion
- Attaques virales
- Débit trop important
- Trafic suspect

Architecture technique IPS

Possibilité pour l'ips de bloquer du trafic légitime s'il y a une erreur d'analyse...

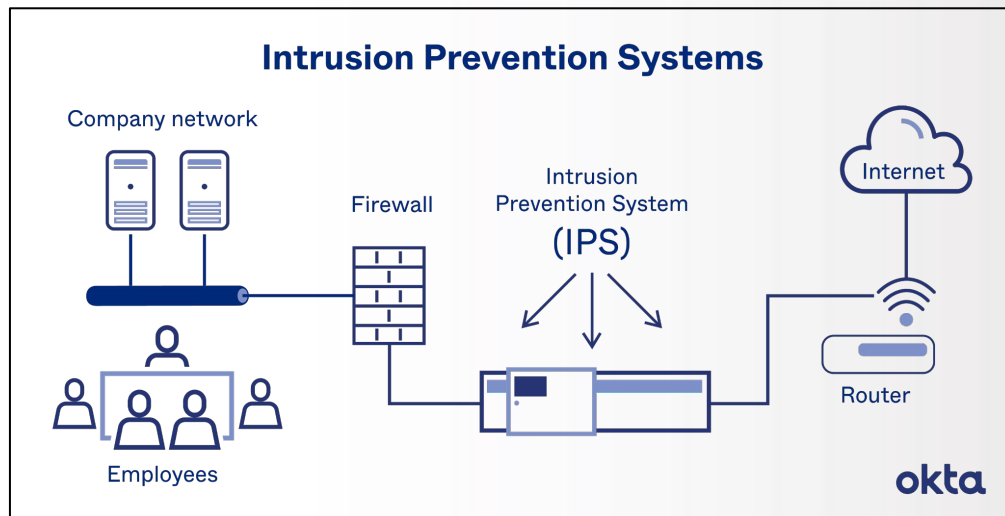


L'ips étant en coupure sur le réseau et non comme l'ids sur un réseau à part, il pourra plus facilement se faire attaquer s'il contient des vulnérabilités.



Architecture Technique NIPS

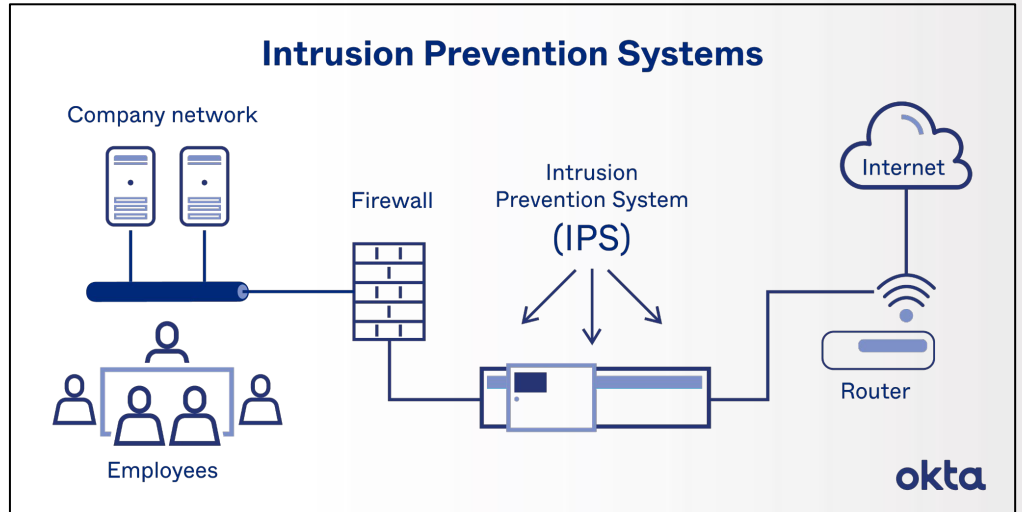
- Analyse le trafic réseau
- S'appuie sur une base de données de signatures d'attaque
- Bloque les flux malveillants



Architecture Technique HIPS

- Analyse les machines hôtes
- Surveille différents éléments des machines hôtes
- Bloque les activités suspectes

Le HIPS peut vérifier les processus, dll, etc.
Mais, il existe 2 inconvénients...



Solution IDS / IPS

HIDS/HIPS

- Tripwire
- OSSEC
-



NIDS/NIPS

- Snort
- Suricata
- Prelude
- ...



Termes importants

> Faux positifs

- Fausse alerte remontée

> Vrai négatifs

- Comportement suspect qui n'a pas été repéré

> Techniques d'évasion

- techniques permettant de dissimuler une attaque/intrusion et de la rendre invisible pour la solution de sécurité.



Exercices : 1-2-3-4-5

A yellow L-shaped graphic element consisting of a horizontal line at the top and a vertical line on the right, forming an open square frame.

Fin du Module 4
IPREC